



ACTIVIDAD 05

Cartografiando el pentesting: análisis comparativo de metodologías de seguridad informática

CNO V

Seguridad Informática

José Vicente Rodríguez Rivera

179954

	Descripción	Fases de implementación	Objetivo principal	Escenarios en que se utiliza	Orientación	Autores	URL oficial	Certificación asociada	Versiones
MITRE ATT&CK	Marco de conocimiento que documenta de forma estructurada las tácticas, técnicas y procedimientos usados por actores de amenazas reales durante fases de un ciberataque	Se definen tácticas representando objetivos del atacante: Reconnaissance; Resource Development; Initial Access; Execution; Persistence; Privilege Escalation; Defense Evasion; Credential Access; Discovery; Lateral Movement; Collection; Command and Control; Exfiltration; Impact	Identificar y clasificar comportamientos de ataque Analizar amenazas avanzadas Evaluar cobertura de detección y respuesta Mapear controles de seguridad frente a técnicas reales	Análisis de amenazas Evaluación de detección en centros de operación de seguridad (SOC) Red y Blue Team Diseño y validación de controles de seguridad Mapeo de incidentes de seguridad reales	Evaluación y defensa: simulación de ataques; mejora de capacidades defensivas	MITRE Corporation, organización sin fines de lucro financiado por el gobierno de Estados Unidos	https://attack.mitre.org/	No se trata de una certificación. Usada como base teórica y práctica para certificaciones y entrenamientos de terceros	Actualizado periódicamente y publicado en el sitio web oficial
OWASP WSTG	Metodología estructurada para realización de pruebas de seguridad en aplicaciones web, donde se define qué probar, cómo probarlo y por qué	Organizado en categorías de pruebas: Information Gathering; Configuration and Deployment Management Testing; Identity Management Testing; Authentication Testing; Authorization Testing; Session Management Testing; Input Validation Testing; Error Handling;	Identificar vulnerabilidades de seguridad en aplicaciones web, evaluando fallas en controles técnicos, lógicos y de configuración	Pentesting de aplicaciones web Auditorías de seguridad en desarrollo y producción Secure SDLC y DevSecOps Evaluaciones de cumplimiento de seguridad web Validación de controles antes de despliegues productivos	Evaluación ofensiva controlada, orientada a testing técnico, con impacto en mejora defensiva	Desarrollado por OWASP, comunidad abierta de seguridad de software	https://owasp.org/www-project-web-security-testing-guide/	No es una certificación oficial Usado como referencia técnica en programas de capacitación de terceros	Actualizaciones constantes a través del sitio oficial

		Cryptography; Business Logic Testing; Client-side Testing							
NIST SP 800-115	Guía técnica oficial para planificación, ejecución y reporte de pruebas técnicas de seguridad, estableciendo lineamientos estandarizados para evaluar la efectividad de controles de seguridad	Define un proceso estructurado: Planning; Discovery; Attack; Reporting	Evaluar la efectividad de controles de seguridad técnica mediante pruebas estructuradas, para identificar debilidades, validar configuraciones y apoyar la gestión de riesgos	Evaluaciones de seguridad en entornos gubernamentales y empresariales Auditorías técnicas de infraestructura y sistemas Validación de controles de seguridad Pruebas autorizadas de penetración Programas de gestión de riesgos y cumplimiento normativo	Evaluación técnica, con enfoque controlado y formal, orientado a la validación de la seguridad	Publicado por NIST, organismo del Departamento de Comercio de Estados Unidos	https://www.nist.gov/privacy-framework/nist-sp-800-115	No es una certificación Referencia normativa y técnica para auditorías, cumplimiento regulatorio y programas de seguridad	Documento vigente SP 800-115 Permanece como guía de referencia estable en el marco NIST
OSSTMM	Metodología formal y científica para medición objetiva de la seguridad, que establece procedimientos estandarizados para evaluar la exposición y resiliencia de sistemas, redes y procesos	Procesos de evaluación: Scope Definition; Rules of Engagement; Information Gathering; Security Testing; Analysis and Correlation; Reporting	Medir de forma objetiva y verificable nivel de seguridad de un sistema, eliminando sesgos subjetivos y permitiendo comparaciones consistentes entre evaluaciones de seguridad	Auditorías técnicas de seguridad Evaluaciones de infraestructura y redes Medición de exposición organizacional Comparación de niveles de seguridad entre sistemas Programas de mejora	Evaluación y medición, orientada al análisis técnico objetivo	Desarrollado por ISECOM	https://www.isecom.org/OSSTMM.3.pdf	Existen certificaciones basadas en OSSTMM ofrecidas por ISECOM	OSSTMM 3

				continua de seguridad					
PTES	Estándar operativo que define un marco completo y práctico para ejecución de pruebas de penetración, cubriendo desde interacción inicial con el cliente hasta la explotación técnica y reporte de resultados	Pre-engagement Interactions; Intelligence Gathering; Threat Modeling; Vulnerability Analysis; Exploitation; Post-Exploitation; Reporting	Estandarizar la ejecución profesional de pruebas de penetración, asegurando consistencia técnica, control de riesgo, claridad de alcance y resultados accionables	Pentesting de infraestructura y redes Evaluaciones de seguridad corporativas Ejercicios Red Team controlados Validación de postura de seguridad técnica Auditorías técnicas con enfoque ofensivo	Ataque (ofensivo controlado), con impacto directo en la mejora defensiva mediante hallazgos técnicos explotables	Desarrollado por PTES, profesionales de seguridad y pentesting	http://www.pentest-standard.org/index.php/Main_Page	No es una certificación oficial Usado como marco de referencia en certificaciones y entrenamientos de pentesting	Estándar estable, publicado en su sitio oficial No se versiona frecuente
ISSAF	Marco metodológico detallado para evaluación técnica de la seguridad de sistemas de la información, que proporciona procedimientos extensivos para identificación, análisis y validación de vulnerabilidades en entornos tecnológicos complejos	Proceso integral: Planning and Preparation; Assessment and Testing; Analysis; Reporting; Follow-up	Realizar evaluaciones exhaustivas de seguridad sobre sistemas de la información, identificando debilidades técnicas y operativas mediante pruebas controladas y análisis detallado	Evaluaciones de seguridad de sistemas de la información Auditorías técnicas profundas Pruebas de penetración estructuradas Análisis de infraestructura, redes y servicios Programas de mejora de la postura de seguridad	Evaluación técnica con enfoque ofensivo controlado	Desarrollado por OISSG, enfocado en marcos abiertos para evaluación de seguridad	https://untrustednetwork.net/files/issaf0.2.1.pdf	No cuenta con certificaciones propias Usado como referencia metodológica en entrenamientos y programas de seguridad ofensiva	Versión documentada: ISSAF 0.2.1 No presenta actualizaciones recientes

Bibliografía:

Cisco Networking Academy. (2026). 1.2 Exploración de las metodologías de pruebas de penetración. Recuperado el 12 de febrero de 2026, de Cisco Networking Academy | Seguridad Informática-Hacker ético:
<https://www.netacad.com/launch?id=3b07bfc3-9b21-4dbd-909b-a235416df136&tab=curriculum&view=3d7507ef-98e1-51ac-b102-6bdb7618f7a4>

ISECOM. (2026). Research. Recuperado el 12 de febrero de 2026, de ISECOM:
<https://www.isecom.org/research.html#content5-9d>

MITRE Corporation. (2025). Get Started. Recuperado el 12 de febrero de 2026, de MITRE ATT&CK: <https://attack.mitre.org/resources/>

MITRE Corporation. (2026). ATT&CK. Recuperado el 12 de febrero de 2026, de MITRE ATT&CK: <https://attack.mitre.org>

MITRE Corporation. (2026). MITRE ATT&CK DEFENDER™ (MAD). Recuperado el 12 de febrero de 2026, de MAD20: <https://mad20.com>

National Institute of Standards and Security (NIST). (septiembre de 2008). NIST SP 800-115 Technical Guide to Information Security Testing and Assessment. Recuperado el 12 de febrero de 2026, de CSRC NIST:
<https://csrc.nist.gov/pubs/sp/800/115/final>

National Institute of Standards and Security (NIST). (2026). NIST Cybersecurity Professional®. Recuperado el 12 de febrero de 2026, de NIST Cybersecurity Professional: <https://www.nistcybersecurityprofessional.website/nist-800-115-awareness-certificate>

OISSG. (30 de abril de 2006). Information Systems Security Assessment Framework (ISSAF) Draft 0.2.1. Recuperado el 12 de febrero de 2026, de Untrusted Network: <https://untrustednetwork.net/files/issaf0.2.1.pdf>

Open Information Security Group (OISSG). (2024). ISSAF. Obtenido de PYMESEC:
<https://pymesec.org/issaf/>

OWASP. (03 de diciembre de 2020). Release v4.2. Recuperado el 12 de febrero de 2026, de GitHub: <https://github.com/OWASP/wstg/releases/tag/v4.2>

OWASP. (2026). OWASP Web Security Testing Guide. Recuperado el 12 de febrero de 2026, de OWASP: <https://owasp.org/www-project-web-security-testing-guide/>

OWASP. (2026). OWASP Web Security Testing Guide. Recuperado el 12 de febrero de 2026, de GitHub: <https://github.com/OWASP/wstg>

OWASP. (2026). OWASP Web Security Testing Guide Training Course. Recuperado el 12 de febrero de 2026, de NobleProg:
<https://www.nobleprog.mx/en/cc/owaspwstg>

OWASP. (2026). WSTG - Latest. Recuperado el 12 de febrero de 2026, de OWASP:
https://owasp.org/www-project-web-security-testing-guide/latest/4-Web_Application_Security_Testing/00-Introduction_and_Objectives/README

PTES. (16 de agosto de 2014). Main Page. Recuperado el 12 de febrero de 2026, de PentTest Standard: http://www.pentest-standard.org/index.php/Main_Page